

ISO 27001 Controls – One Page Executive Summary

This document summarises the book *ISO 27001 Controls: A Guide to Implementing and Auditing (Second Edition)* by Bridget Kenyon, aligned to ISO/IEC 27001:2022 and ISO/IEC 27002:2022.

Purpose and Scope

The guide provides practical implementation and audit guidance for Annex A controls of ISO/IEC 27001:2022, supporting organisations preparing for ISMS certification or strengthening an existing ISMS. It focuses on controls rather than Clauses 4–10 process requirements.

Audience

ISMS implementers, auditors, risk and compliance professionals, cybersecurity leaders, and organisations seeking ISO/IEC 27001 certification or maturity improvement.

Structure

The book covers all 93 Annex A controls grouped into Organizational, People, Physical, and Technological controls. Each control is explained from both implementation and auditing perspectives.

Key Contributions

- Risk-based control selection and justification via the Statement of Applicability
- Use of control attributes to balance preventive, detective, and corrective controls
- Strong emphasis on governance, ownership, and accountability
- Clear audit evidence expectations and common pitfalls
- Updated guidance for cloud, supply chain, threat intelligence, secure development, logging, and privacy

Practical Value

Acts as an implementation playbook, internal audit checklist, certification preparation guide, and bridge between ISO standards and operational practice.

Conclusion

The guide positions ISO 27001 controls as operational, auditable, and risk-driven safeguards that enable business resilience, trust, and regulatory confidence.